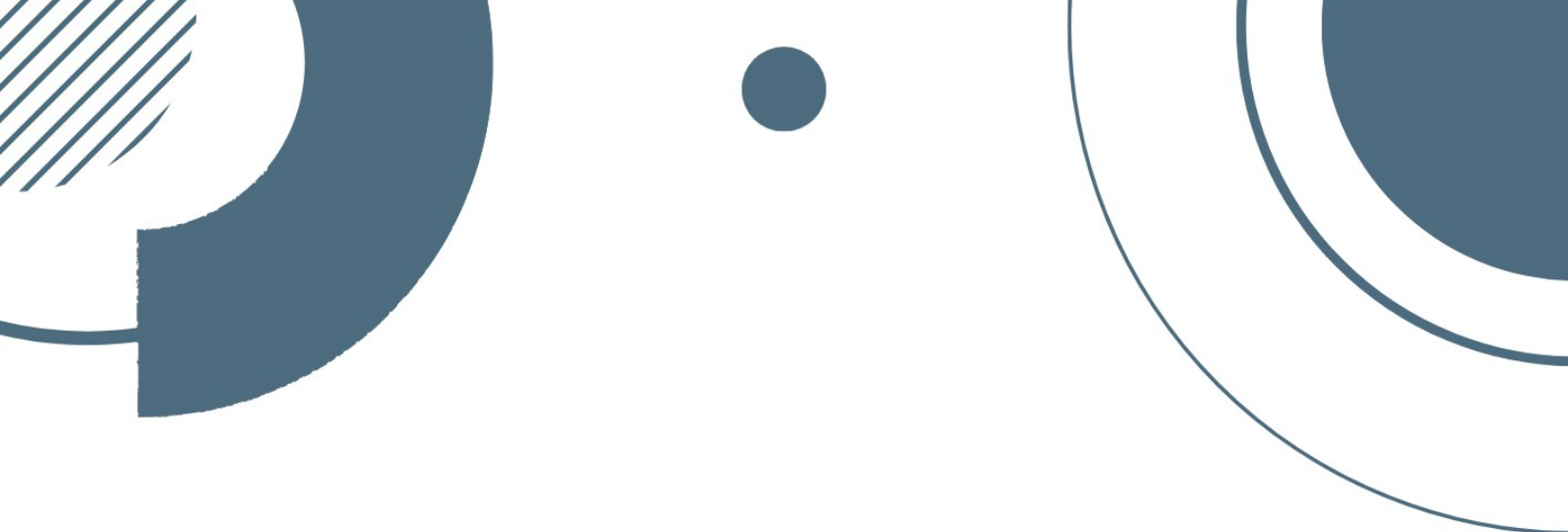




PUESTA EN PRODUCCIÓN
SEGURA



BROKEN ACCESS CONTROL



Carles Ochoa



Índice

Introducción.....3

Juice Shop.....3

DVWA..... 10

Introducción

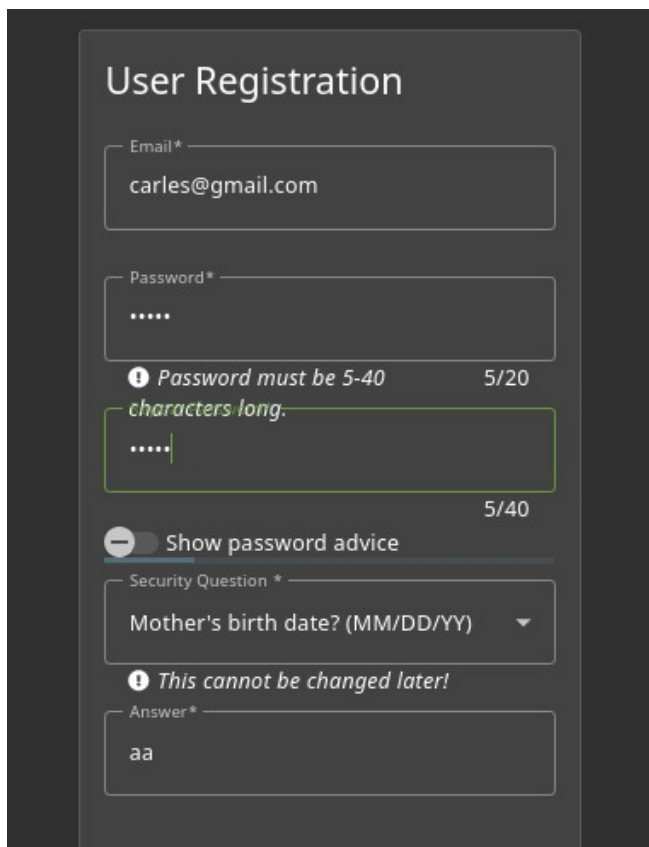
En esta práctica de Broken Access Control, vamos a aprender a identificar y explotar vulnerabilidades críticas de seguridad donde los controles de acceso fallan, permitiendo a usuarios acceder a recursos o realizar acciones que no deberían estar autorizados a ejecutar. Para ello realizaremos una serie de retos.

Juice Shop

Reto 1: Ver la cesta de otro usuario en Juice Shop

En el primer reto veremos como vulnerar juice shop para obtener la cesta de otro usuario.

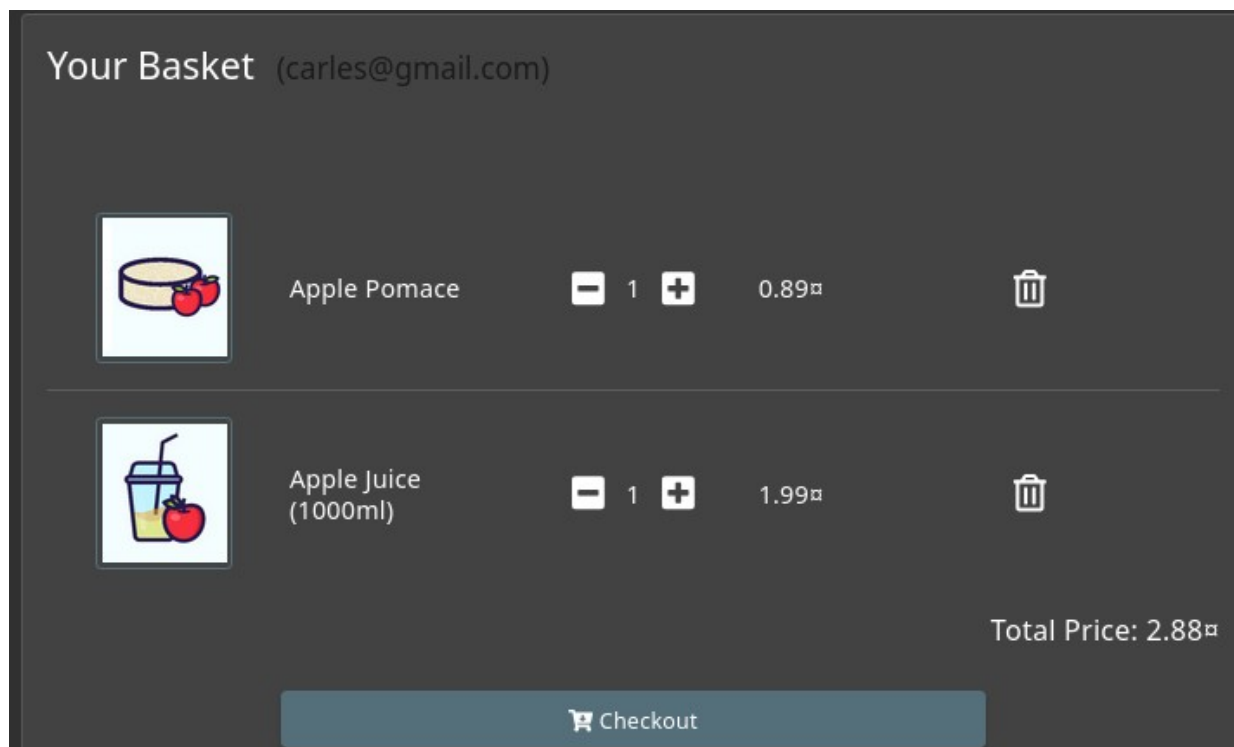
El primer paso es crear un usuario nuevo.



The image shows a 'User Registration' form in a dark-themed application. The form contains the following fields and elements:

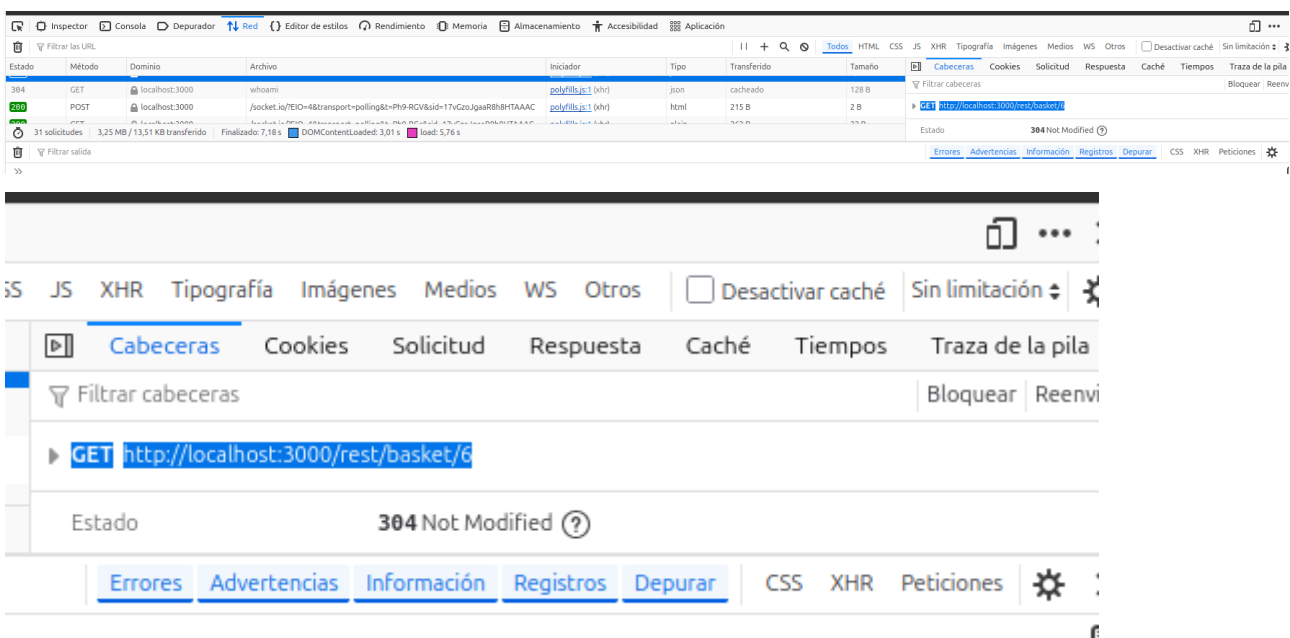
- Email ***: A text input field containing 'carles@gmail.com'.
- Password ***: A text input field with masked characters '.....'.
- Password strength indicator**: Below the password field, it says 'Password must be 5-40 characters long.' with a '5/20' character count.
- Confirm Password**: A second text input field with masked characters '.....' and a '5/40' character count.
- Show password advice**: A toggle switch that is currently turned off.
- Security Question ***: A dropdown menu with the selected option 'Mother's birth date? (MM/DD/YY)'.
- Warning**: Below the security question, a message states 'This cannot be changed later!'.
- Answer ***: A text input field containing 'aa'.

Con el usuario ya creado, añadiremos productos a la cesta.



El siguiente paso es capturar la petición de ver la cesta. Para ello pulsamos F12 y en la pestaña Red buscamos la petición <http://localhost:3000/rest/basket/6>.

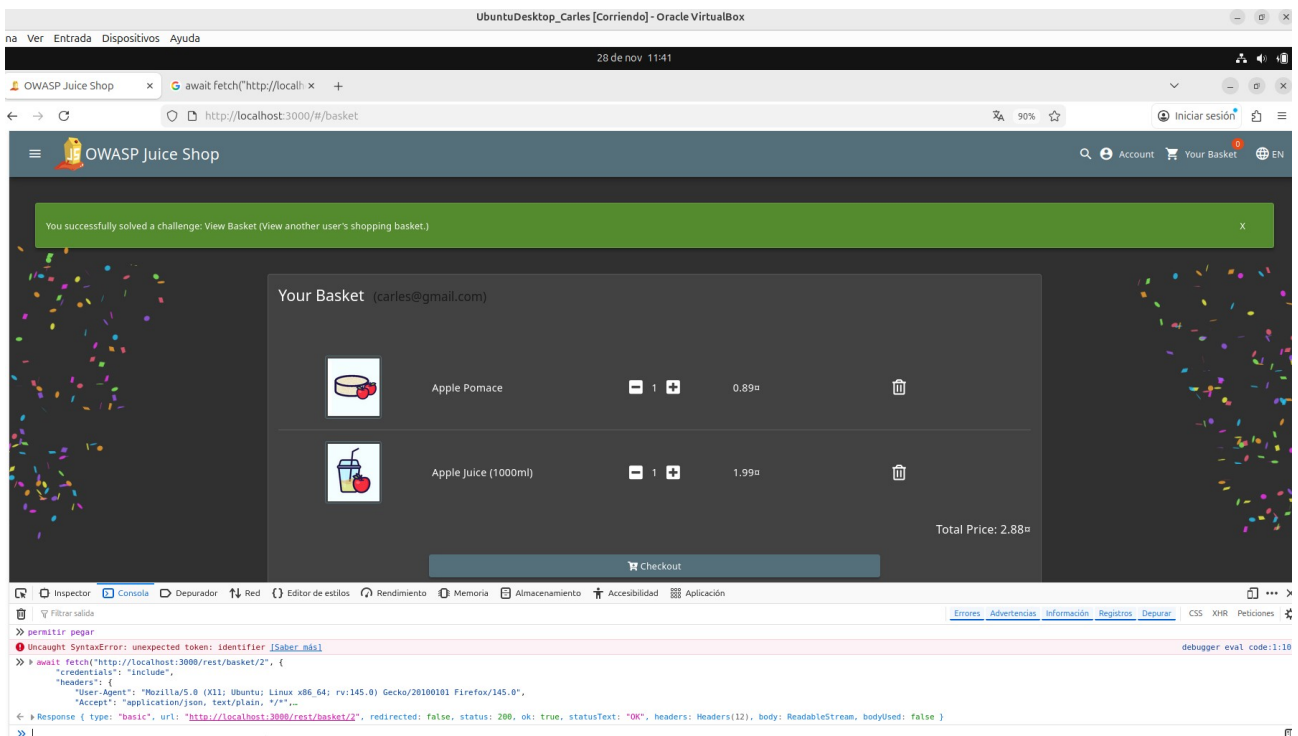
El número 6 es el identificador de el usuario, que en este caso es el usuario carles@gmail.com.



Con esta petición ya localizada pulsaremos clic derecho sobre ella Copiar»Copy como fetch.

Seguidamente nos dirigiremos a la pestaña console. Y una vez aquí como el objetivo es ver la cesta de otro usuario lo que deberemos es substituir el 6 por otro número, por ejemplo el dos, y al pegar la petición que hemos copiado anteriormente veremos que hemos resuelto el reto correctamente y Juice Shop nos notificará sobre ello.

Y veremos la cesta del usuario 2.



Este ataque ocurre porque el servidor no comprueba si la cesta pertenece al usuario que hace la petición.

Al usar una URL como `/rest/basket/6`, basta con cambiar el número por otro (`/rest/basket/2`) para ver la cesta de otro usuario, ya que no hay control de acceso en el backend.

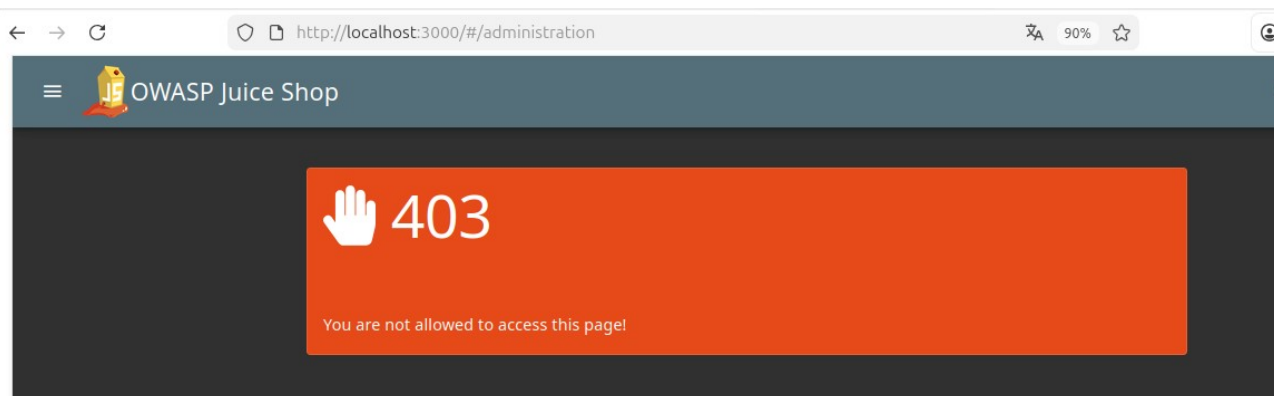
Reto Juice Shop: Acceso a la sección de administración de la tienda

Para acceder a la sección de administración de la página los pasos a seguir son los siguientes:

1. Pulsar clic derecho sobre la página para ver el código fuente.
2. En el código fuente veremos la ruta <http://localhost:3000/#/administration>. Por lo tanto sabemos que esta es la sección de la administración de la tienda.

```
→ ↻ No seguro view-source:http://localhost:3000/#/
1 <!--
2 ~ Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
3 ~ SPDX-License-Identifier: MIT
4 -->
5
6 <!doctype html>
7 <html lang="en" data-beasties-container>
8 <head>
9   <meta charset="utf-8">
10  <title>OWASP Juice Shop</title>
11  <meta name="description" content="Probably the most modern and sophisticated insecure web application">
12  <meta name="viewport" content="width=device-width, initial-scale=1">
13  <link id="favicon" rel="icon" type="image/x-icon" href="assets/public/favicon.js.ico">
14  <link rel="stylesheet" type="text/css" href="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.css">
15  <script src="//cdnjs.cloudflare.com/ajax/libs/cookieconsent2/3.1.0/cookieconsent.min.js"></script>
16  <script src="//cdnjs.cloudflare.com/ajax/libs/jquery/2.2.4/jquery.min.js"></script>
17  <script>
18    window.addEventListener("load", function(){
19      window.cookieconsent.initialise({
20        "palette": {
21          "popup": { "background": "var(--theme-primary)", "text": "var(--theme-text)" },
22          "button": { "background": "var(--theme-accent)", "text": "var(--theme-text)" }
23        },
24        "theme": "classic",
25        "position": "bottom-right",
26        "content": { "message": "This website uses fruit cookies to ensure you get the juiciest tracking experience.", "dismiss": "Me want it!", "link": "But me wait!", "href":
27      });
28    </script>
29    <style>html{--mat-sys-on-surface:initial}.mat-app-background{background-color:var(--mat-app-background-color, var(--mat-sys-background, transparent));color:var(--mat-app-text-c
30  <body class="mat-app-background mat-typography bluegrey-lightgreen-theme">
31    <app-root></app-root>
32    <script src="runtime.js" type="module"></script><script src="polyfills.js" type="module"></script><script src="vendor.js" type="module"></script><script src="main.js" type="mod
33  </html>
34
```

3. Si introducimos la dirección encontrada en el navegador nos aparecerá una ventana informándonos que no tenemos permisos suficientes para acceder a ella.



4. Para resolver este problema de permisos debemos iniciar sesión como administrador y lo haremos mediante inyección SQL. Por lo tanto en el login introduciremos la inyección ' OR 1=1-- con contraseña cualquiera y ya tendremos la sesión iniciada como administradores y con los suficientes permisos.

Login

Email*
' OR 1=1--

Password*
..

[Forgot your password?](#)

 Log in

☐ Remember me

or

 Log in with Google

[Not yet a customer?](#)

UbuntuDesktop_Carles [S'està executant] - Oracle VM VirtualBox

28 de nov 16:16

OWASP Juice Shop

http://localhost:3000/#/

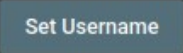
localhost:3000/profile

User Profile

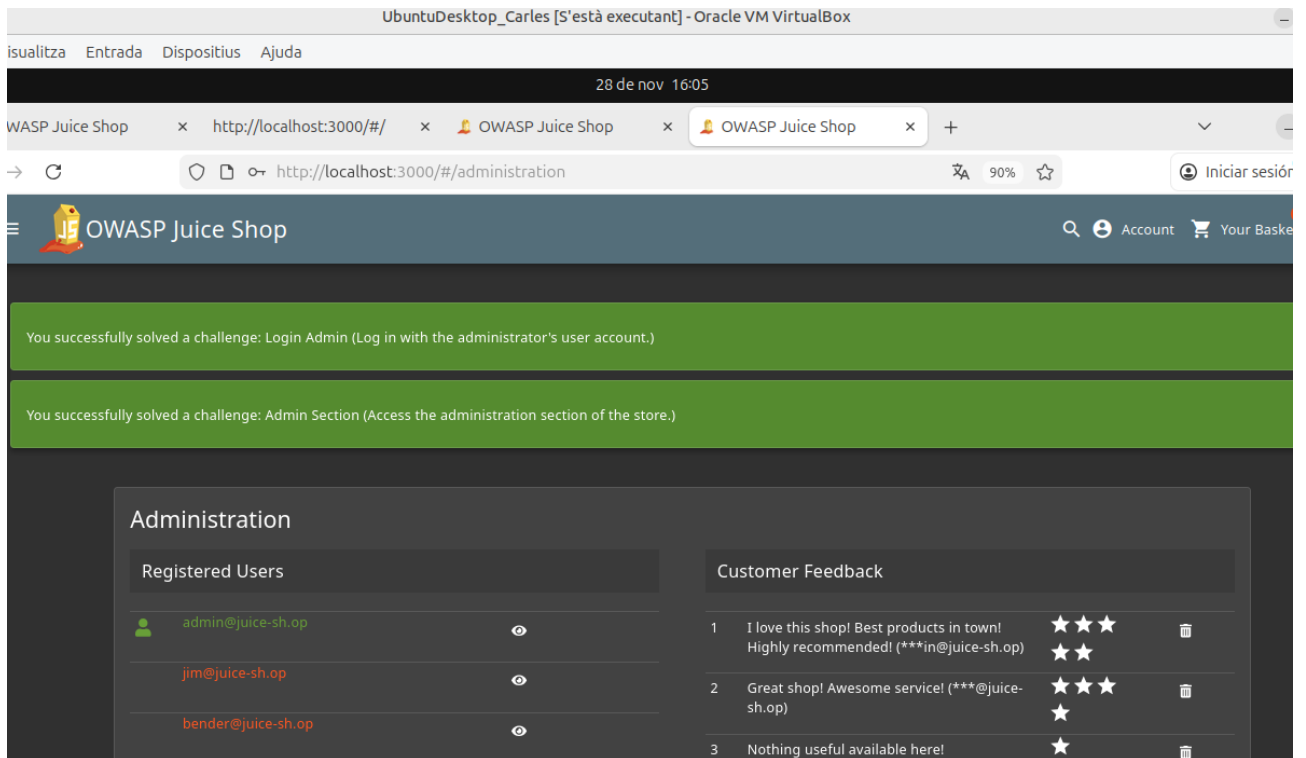


Email:
admin@juice-sh.op

Username:
e.g. SuperUser

 Set Username

5. Si ahora introducimos la url <http://localhost:3000/#/administration> ya estaremos en la sección de administración de la tienda.



Esto sucede porque la aplicación de Juice Shop tiene un problema grave: revela información sensible en el código que se envía al navegador.

Cuando abrimos la página web, el navegador descarga no solo lo que vemos, sino también archivos JavaScript que contienen todas las rutas y funcionalidades de la aplicación. Y en estos archivos JavaScript es donde hemos encontrado esta ruta (<http://localhost:3000/#/administration>).

Reto Juice Shop: Eliminar comentarios de 5 estrellas.

Para eliminar estos comentarios necesitaremos llegar hasta el punto anterior, es decir a la url <http://localhost:3000/#/administration> y aquí encontraremos todos los comentarios.

The screenshot shows the administration interface of the Juice Shop. On the left, there is a list of registered users. On the right, there is a list of customer reviews. The reviews section is highlighted with a red box.

Usuarios Registrados	
admin@juice-sh.op	👁
im@juice-sh.op	👁
bender@juice-sh.op	👁
bjoern.kimminich@gmail.com	👁
ciso@juice-sh.op	👁
support@juice-sh.op	👁
morty@juice-sh.op	👁
mc.safesearch@juice-sh.op	👁
12934@juice-sh.op	👁
wurstbrot@juice-sh.op	👁

Opiniones de los clientes	
1	I love this shop! Best products in town! Highly recommended! (**in@juice-sh.op) ★★★★★
2	Great shop! Awesome service! (**@juice-sh.op) ★★★★★
3	Nothing useful available here! (**der@juice-sh.op) ★
21	Please send me the juicy chatbot NFT in my wallet at /juicy-nft : "purpose betray marriage blame crunch monitor spin slide donate sport lift clutch" (**ereum@juice-sh.op) ★
	Incompetent customer support! Can't even upload photo of broken purchase! Support Team: Sorry, only order confirmation PDFs can be attached to complaints! (anonymous) ★★
	This is the store for awesome stuff of all kinds! (anonymous) ★★★★★
	Never gonna buy anywhere else from now on! Thanks for the great service! (anonymous) ★★★★★
	Keep up the good work! (anonymous) ★★★★★

Eliminamos todos los que tengan 5 estrellas y deberá quedar como la siguiente captura:

The screenshot shows the administration interface of the Juice Shop after removing all 5-star reviews. The reviews section now only contains reviews with 1, 2, or 3 stars.

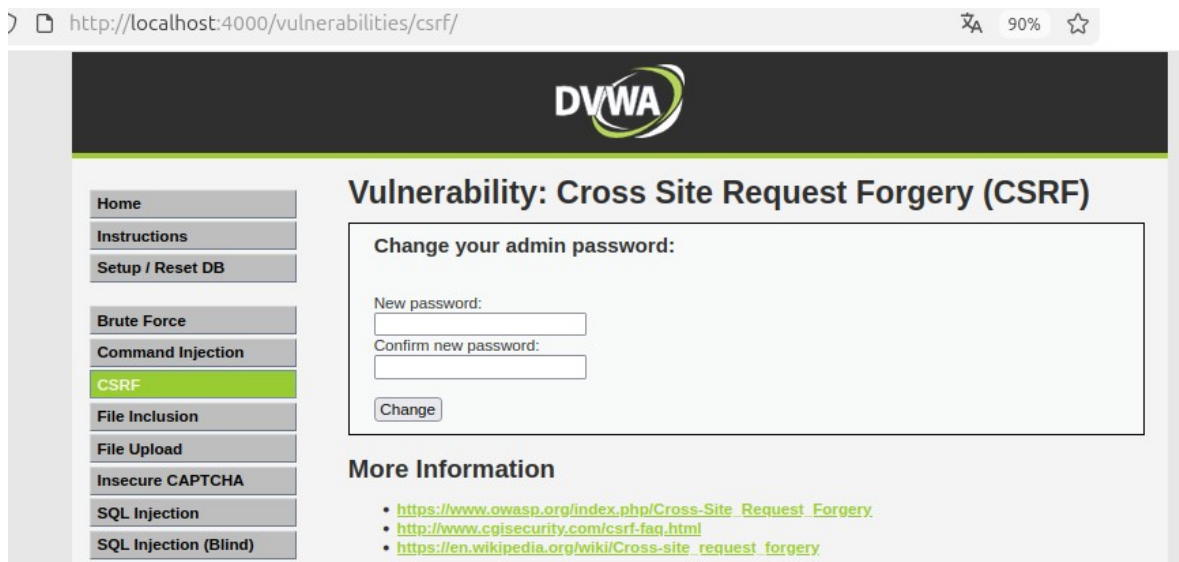
Usuarios Registrados	
admin@juice-sh.op	👁
im@juice-sh.op	👁
bender@juice-sh.op	👁
bjoern.kimminich@gmail.com	👁
ciso@juice-sh.op	👁
support@juice-sh.op	👁
morty@juice-sh.op	👁
mc.safesearch@juice-sh.op	👁
12934@juice-sh.op	👁
wurstbrot@juice-sh.op	👁

Opiniones de los clientes	
2	Great shop! Awesome service! (**@juice-sh.op) ★★★★★
3	Nothing useful available here! (**der@juice-sh.op) ★
21	Please send me the juicy chatbot NFT in my wallet at /juicy-nft : "purpose betray marriage blame crunch monitor spin slide donate sport lift clutch" (**ereum@juice-sh.op) ★
	Incompetent customer support! Can't even upload photo of broken purchase! Support Team: Sorry, only order confirmation PDFs can be attached to complaints! (anonymous) ★★
	This is the store for awesome stuff of all kinds! (anonymous) ★★★★★
	Never gonna buy anywhere else from now on! Thanks for the great service! (anonymous) ★★★★★
	Keep up the good work! (anonymous) ★★★★★

DVWA

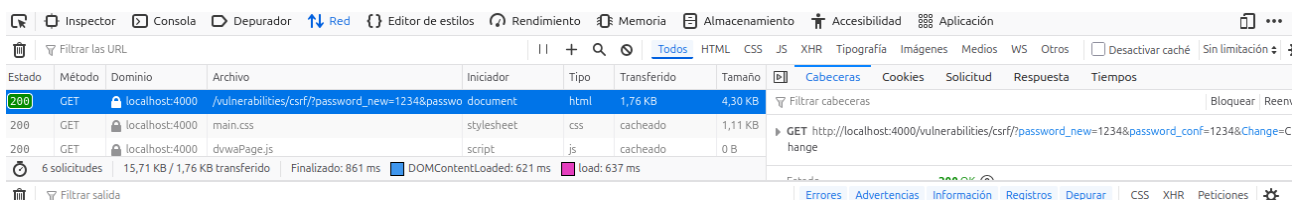
CSRF en DVWA - Cambiar contraseña de administrador

Para cambiar la contraseña del administrador, el primer paso es acceder a la sección CSRF de DVWA para identificar el formulario de cambio de contraseña con los campos:



El siguiente paso es capturar la petición http utilizando las DevTools del navegador (F12):

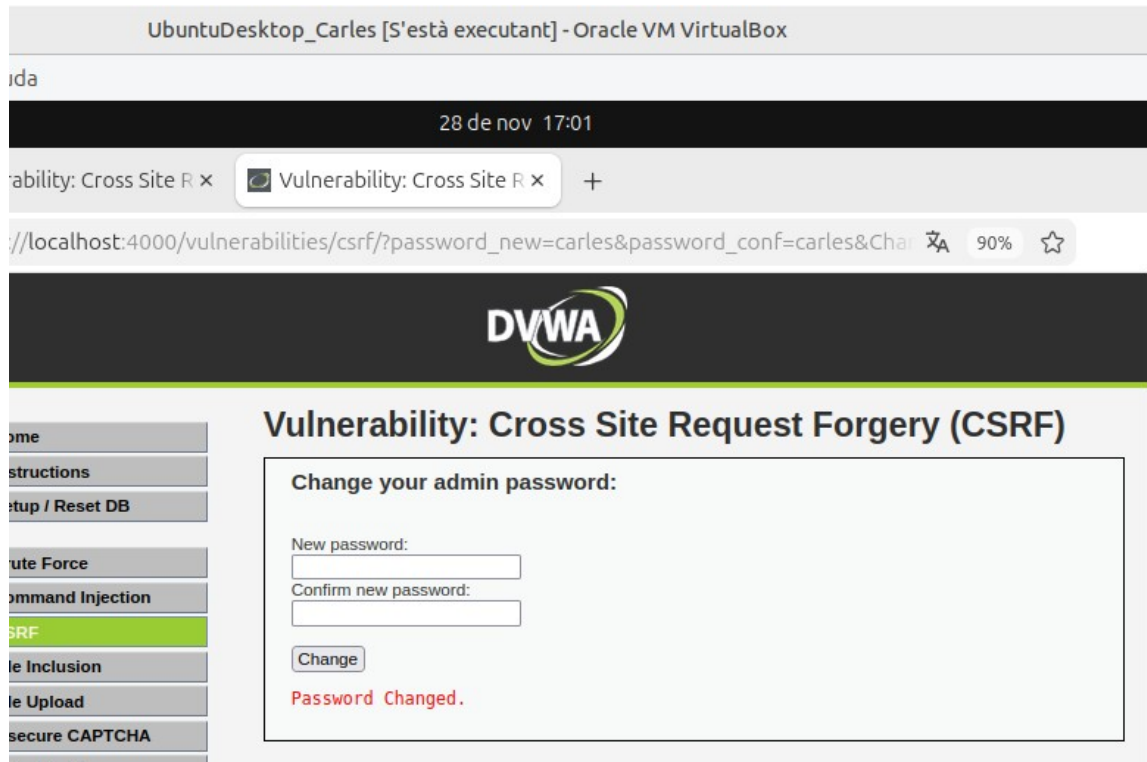
- Abrimos la pestaña red
- Ejecutamos un cambio de contraseña de prueba
- Interceptamos la petición GET con los parámetros:



Con la petición ya identificada crearemos una url maliciosa. Por ejemplo introduciendo como contraseña carles:

http://localhost:4000/vulnerabilities/csrf/?password_new=carles&password_conf=carles&Change=Change

Si ahora introducimos esta url maliciosa en el navegador veremos que la contraseña del usuario admin se cambiará correctamente.



Por lo tanto si ahora introducimos otra contraseña que no sea carles nos aparecerá Login failed

